

CIBERSEGURIDAD DEFENSIVA

Catálogo de Respuesta a Incidentes · Blue Team

SOC-IR-041	SOC-IR-042	SOC-IR-043
PHISHING Vector de entrada más frecuente en incidentes graves	RANSOMWARE Mayor impacto operativo inmediato	DDoS Interrupción de disponibilidad sin comprometer datos

Marcos de referencia:

NIST SP 800-61 Rev. 2 MITRE ATT&CK SANS ISO/IEC 27035

Contenido del catálogo

- 3 Playbooks operativos — 13 secciones cada uno
- 3 Informes técnicos de diseño y revisión
- 3 Diagramas de flujo granulares (mínimo 3 herramientas por fase)
- Resumen de clase de 20 páginas sincronizado con los playbooks

9 Documentos del catálogo	6 Fases NIST cubiertas	15 Técnicas MITRE	4 Marcos de referencia
-------------------------------------	----------------------------------	-----------------------------	----------------------------------

15 técnicas MITRE ATT&CK cubiertas:

T1566	T1566.001	T1566.002	T1114.003	T1078	T1059.001	T1486	T1490	T1547	T1070	T1498
T1498.001	T1498.002	T1499	T1584							

"Un incidente bien gestionado no es el que no ocurrió.
Es el que el equipo supo cómo responder."

SOC-IR-041

PLAYBOOK DE RESPUESTA ANTE PHISHING

NIST SP 800-61 · MITRE ATT&CK · SANS · ISO/IEC 27035

Técnicas MITRE: **T1566 Phishing** **T1566.001** **T1566.002** **T1114.003 Forwarding** **T1078 Valid Accounts**

BIFURCACIÓN CRÍTICA DEL TRIAGE

CAMINO A — BAJO RIESGO Usuario reportó sin interactuar · Urgencia: Media < 4h	CAMINO B — ALTO RIESGO Clic / adjunto / credenciales · Urgencia: Alta < 15 min
• Purgar correo de TODOS los buzones (ZAP) • ¿Purga al 100%? Si NO: manual buzón a buzón (IT) • Bloquear remitente, dominio e IP en SEG y firewall • Notificar al usuario: tono directo, no punitivo	• Deshabilitar cuenta y revocar sesiones/tokens (IAM) • ¿Malware confirmado? Aislar endpoint vía EDR • Preservar evidencia forense antes de remediar • Revisar reglas de reenvío (T1114.003) en el buzón

ESCALADO BEC — Business Email Compromise

Llamada telefónica DIRECTA a Tesorería ANTES del ticket. La ventana para detener una transferencia puede ser de minutos.

FASES NIST SP 800-61 — ACCIONES CLAVE

PREPARACIÓN	DETECCIÓN	CONTENCIÓN	ERRADICACIÓN	RECUPERACIÓN
SEG y DMARC configurados Simulacros anti-phishing Contacto Tesorería (BEC)	Verificar SPF/DKIM/DMARC IOCs: URL, hash, remitente EDR/proxy: ¿interacción?	Camino A o B según triage Purga ZAP + bloqueo SEG Revocar sesiones IAM	Reglas reenvío T1114.003 Dispositivos MFA no autorizados Threat hunting con IOCs	Restablecer acceso cuenta Monitorización reforzada Confirmación del usuario

HERRAMIENTAS POR FUNCIÓN

SEG / Detección: Proofpoint TAP · Mimecast · Microsoft Defender for Office 365	IAM / Identidad: Okta · Microsoft Entra ID · Google Workspace
EDR / Endpoint: CrowdStrike Falcon · SentinelOne · Microsoft Defender for Endpoint	Análisis IOCs: VirusTotal · Urlscan.io · Any.run · Joe Sandbox
Gestión del caso: TheHive · ServiceNow ITSM · Jira Service Management	Concienciación: KnowBe4 · Microsoft Attack Simulation Training · Cofense

SOC-IR-042

PLAYBOOK DE RESPUESTA ANTE RANSOMWARE

NIST SP 800-61 · MITRE ATT&CK · SANS · ISO/IEC 27035

Técnicas:

T1566

T1059.001 PowerShell

T1486 Data Encrypted

T1490 Shadow Copies

T1547 Autostart

T1070 Indicator Removal

CADENA DE ATAQUE



CONTENCIÓN VÍA SOAR — MENOS DE 10 SEGUNDOS

API del EDR aísla el host manteniendo el canal de gestión con la consola SOC. Si el SOAR falla: Analista L2 ejecuta contención manual (deshabilitar cuenta AD + bloqueo VPN/RDP + coordinación NOC).

DECISIONES CRÍTICAS DEL PLAYBOOK

EVIDENCIA FORENSE	POSTURA ANTE EL RESCATE	RECUPERACIÓN CONTROLADA
Antes de CUALQUIER remediación: imagen de disco y volcado de memoria del host. Necesario para investigación posterior, reclamación de seguro y procedimiento legal.	NO se paga sin autorización simultánea de Dirección + Legal + CISO. El pago no garantiza recuperar los datos, financia grupos criminales y puede violar sanciones OFAC.	Solo desde backup inmutable y air-gapped verificado. Monitorización reforzada 72 horas tras la reconexión. Confirmación formal de los propietarios del negocio.

CRITERIOS DE ESCALADO

L1 → L2	Confirmación de actividad maliciosa tras el triage	15 min
L2 → L3 / IR Lead	Cifrado activo o 3 o más hosts afectados	30 min
L2 → IR Lead	Fallo de contención SOAR — modo manual activado	INMEDIATO
IR Lead → CISO	Afectación a sistemas críticos, backups o exfiltración	1 hora
IR Lead → Legal	Posible afectación a datos personales (RGPD: 72 horas)	1-2 horas

HERRAMIENTAS CLAVE

EDR / Contención: CrowdStrike Falcon · SentinelOne · Microsoft Defender for Endpoint	SOAR: Cortex XSOAR · Shuffle (open-source) · Tines
SIEM: Splunk Enterprise Security · Microsoft Sentinel · Wazuh + Sysmon	Backup inmutable: Veeam · Cohesity DataProtect · Rubrik Security Cloud
Forense / DFIR: Velociraptor · FTK Imager · Volatility	Gestión del caso: TheHive · ServiceNow ITSM · Jira Service Management

SOC-IR-043

PLAYBOOK DE RESPUESTA ANTE DDoS

NIST SP 800-61 · MITRE ATT&CK · SANS · ISO/IEC 27035

Técnicas:

T1498 Network DoS

T1498.001 Direct Flood

T1498.002 Amplification

T1499 Endpoint DoS

T1584 Infra. Comprometida

CLASIFICACIÓN OBLIGATORIA ANTES DE ACTIVAR CUALQUIER MITIGACIÓN

⚠ **RIESGO: DENEGACIÓN DE SERVICIO AUTO-INFLIGIDA**

Usar la herramienta equivocada bloquea tráfico legítimo. BGP blackholing en ataque de capa 7 deniega a los propios usuarios. CAPTCHA ante 100 Gbps volumétrico es ineficaz. Clasificar el tipo de ataque siempre antes de actuar.

DECISIONES CRÍTICAS DEL PLAYBOOK

VOLUMÉTRICO	DE PROTOCOLO	CAPA 7 (APLICACIÓN)
Ejemplo: UDP flood · Amplificación DNS/NTP · ICMP flood Satura: Ancho de banda de red (Gbps) Scrubbing center nube BGP blackholing (requiere IR Lead)	Ejemplo: SYN flood · IP fragmentation · ACK flood Satura: Tabla de estado del firewall o CPU red SYN proxy en firewall FortiDDoS Radware DefensePro	Ejemplo: HTTP flood · Slowloris · Scraping masivo Satura: Recursos del servidor web o aplicación WAF con rate limiting CAPTCHA challenge TLS fingerprinting

DECISIONES OPERATIVAS

BGP BLACKHOLING	COORDINACIÓN ISP	MONITORIZACIÓN 24H
Último recurso: acepta la indisponibilidad total de la IP como mal menor. Requiere autorización explícita del IR Lead. El Analista L1 no puede activarlo de forma autónoma.	El contacto 24/7 con el ISP y el proveedor anti-DDoS debe estar documentado antes del primer ataque. Sin esto, la activación del blackholing puede tardar horas.	Mínimo 24 horas post-recuperación con alertas activas. Los atacantes relanzan el ataque tras una pausa corta al detectar que los controles de emergencia se desactivaron.

CRITERIOS DE ESCALADO

L1 → L2	Ataque confirmado supera el umbral de activación	15 min
L2 → Proveedor anti-DDoS	Activación del scrubbing center en la nube	15 min
L2 → Equipo Red / NOC	ACLs en router de borde o BGP blackholing	30 min
L2 → IR Lead	Servicios caídos o duración superior a 30 minutos	30 min
IR Lead → autoriza	Scrubbing insuficiente para absorber el ataque	INMEDIATO
IR Lead → CISO	Impacto en SLA con clientes o interrupción > 1 hora	1 hora

HERRAMIENTAS CLAVE

Anti-DDoS cloud: Cloudflare Magic Transit · AWS Shield Advanced · Akamai Prolexic	Monitorización red: Kentik Network Observability · NetFlow/sFlow · PRTG · Zabbix
WAF y CDN: Cloudflare WAF · AWS WAF · F5 BIG-IP ASM	Firewall / Router: Palo Alto NGFW · Fortinet FortiGate · Juniper MX (BGP RTBH)
Gestión del caso: TheHive · ServiceNow ITSM · Jira Service Management	SIEM / Análisis: Splunk Enterprise Security · Microsoft Sentinel · Suricata IDS

COMPARATIVA Y LECCIONES APRENDIDAS

SOC-IR-041 · SOC-IR-042 · SOC-IR-043

LOS TRES INCIDENTES — DIFERENCIAS CLAVE			
	Phishing (041)	Ransomware (042)	DDoS (043)
Compromete datos	SÍ (credenciales)	SÍ (cifrado)	NO
Métrica crítica	MTTD + MTTC	MTTC (< 10 seg)	MTTC
Acción inmediata	Bifurcación A/B	SOAR aislamiento	Clasificar tipo ataque
Riesgo especial	BEC financiero	Reinfección	Auto-denegación servicio
Monitorización post	N días (cuenta)	72 horas	24 horas
Stakeholder clave	Tesorería (BEC)	Legal/CISO/Dirección	ISP + Proveedor
No hacer nunca	Penalizar al usuario	Pagar el rescate	BGP sin IR Lead

LOS 9 ELEMENTOS DE UN PLAYBOOK COMPLETO	
1	Nombre, versión y alcance Define qué cubre y qué NO cubre el playbook
2	Triggers de activación Eventos concretos y medibles, no criterios ambiguos
3	Roles y responsabilidades Quién hace qué — la ambigüedad de mando genera retrasos fatales
4	Las 6 fases NIST completas Sin Erradicación el atacante vuelve. Sin Lecciones no hay mejora
5	Acciones técnicas concretas Herramienta + query + umbral — no "analizar los logs"
6	Mapeo a MITRE ATT&CK Hace auditable la cobertura de detección del equipo
7	Criterios de escalado con tiempos Con destinatario y ventana temporal exactos
8	Pautas de comunicación NOC, CISO, Legal y clientes necesitan información diferente
9	Métricas MTTD/MTTC/MTTR Sin métricas no se puede saber si el equipo mejoró

LA LECCIÓN MÁS IMPORTANTE		
TECNOLOGÍA Herramientas correctas, bien configuradas e integradas entre sí.	PROCESO Playbooks, escalado, post-mortem. Sin proceso la tecnología no activa.	PERSONAS Analistas entrenados, simulacros periódicos y cultura de mejorar.

"Un incidente bien gestionado no es el que no ocurrió.
Es el que el equipo supo cómo responder."

Cobertura MITRE ATT&CK del catálogo:

T1566	T1566.001	T1566.002	T1114.003	T1078	T1059.001	T1486	T1490	T1547	T1070	T1498
T1498.001	T1498.002	T1499	T1584							